



## AI Playbook and Toolkit for Public Health Departments

# Third-Party AI Risk Management

GOV 360

This module focuses on ongoing oversight of vendors, subcontractors, data rights, model updates, and exit plans. It is designed for public health staff who must translate responsible AI principles into repeatable decisions, documents, workflows, and oversight practices. The module helps learners move beyond general awareness by producing a practical artifact that can be used in governance review, implementation planning, operations, communication, or accountability. It emphasizes paragraph-based reasoning, defined responsibilities, and documentation that can withstand public health, legal, privacy, equity, and leadership review.

|                   |                                                                 |
|-------------------|-----------------------------------------------------------------|
| Level             | intermediate/practitioner                                       |
| Primary track     | Governance and Security Track                                   |
| Appears in tracks | governance-security, technical-architecture, program-management |

---

## Learning Objectives

- Explain the purpose of third-party AI risk management in public health AI.
- Identify the roles, decisions, risks, and documentation needed for the topic.
- Apply the topic to a real or realistic public health workflow or decision.
- Recognize equity, privacy, security, legal, operational, and public trust implications.
- Produce a practical artifact that supports readiness, governance, implementation, monitoring, or accountability.

## Module Overview

This module focuses on ongoing oversight of vendors, subcontractors, data rights, model updates, and exit plans. It is designed for public health staff who must translate responsible AI principles into repeatable decisions, documents, workflows, and oversight practices.

The module helps learners move beyond general awareness by producing a practical artifact that can be used in governance review, implementation planning, operations, communication, or accountability. It emphasizes paragraph-based reasoning, defined responsibilities, and documentation that can withstand public health, legal, privacy, equity, and leadership review.

## Definitions

- **Decision right:** The authority to approve, deny, modify, pause, or escalate an AI use case or operational decision.
- **Evidence artifact:** A document, log, checklist, test result, approval record, or review note that demonstrates responsible AI practice.
- **Escalation pathway:** A defined route for raising concerns to the appropriate reviewer or decision-maker.
- **Accountability owner:** The person or role responsible for ensuring that an AI use case is governed, monitored, and corrected when needed.
- **Operational safeguard:** A procedure, control, or review step that reduces risk during day-to-day use.

## Jurisdiction and Agency Policy Note

This module provides national-level training guidance for public health agencies and partners. It is not legal advice and does not replace review by agency legal counsel, privacy officers, procurement officials, civil rights staff, records officers, or other authorized decision-makers. Requirements may vary by state, locality, territory, Tribe, agency, funding source, data-sharing agreement, emergency authority, and organizational policy. Learners should use this module to identify the issues that require review and should confirm applicable requirements before approving, procuring, deploying, or publicly communicating about AI-supported work.

## Why This Topic Matters for Public Health AI

Third-Party AI Risk Management matters because AI adoption changes how public health agencies make, document, communicate, and review decisions. Without a structured approach, staff may rely on informal practices, vendor assurances, or one-time approvals that do not match the operational consequences of AI-supported work.

Public health agencies operate under legal authorities, public accountability, resource constraints, and community trust obligations. A module on this topic helps agencies define repeatable expectations before urgent situations arise. It also helps staff distinguish low-risk administrative support from uses that affect surveillance, public communications, field response, resource allocation, civil rights, privacy, or official records.

---

## Public Health Example

A public health agency is preparing to use AI in a workflow related to ongoing oversight of vendors, subcontractors, data rights, model updates, and exit plans. The project team initially treats the tool as a helpful efficiency aid, but governance reviewers recognize that the workflow may affect public trust, equity, official records, or public health action.

The agency responds by creating a clear artifact that defines intended use, prohibited use, responsible roles, review points, documentation expectations, escalation triggers, and monitoring measures. This converts a broad AI idea into a manageable public health practice.

## Technical and Operational Deep Dive

The first step in this topic is to define the decision or workflow clearly. Staff should identify who is affected, what data are used, what AI output is produced, who reviews the output, and what action may follow. This prevents the module from becoming abstract and anchors the work in public health practice.

The second step is to assign responsibilities. AI-supported workflows often cross program, IT, legal, privacy, communications, procurement, and leadership boundaries. Responsibilities should be named by role rather than assumed. The artifact should specify who prepares materials, who reviews risks, who approves use, who monitors performance, and who can pause or revise the workflow.

The third step is to define evidence. Responsible AI depends on more than policy statements. Agencies need records that show what was reviewed, what decisions were made, what safeguards were applied, what incidents occurred, and how the workflow changed over time. Evidence also supports audits, public records review, quality improvement, and leadership accountability.

## Risks, Failure Modes, and Guardrails

A common failure mode is treating the topic as a one-time checklist. AI risks can change when data sources, models, vendors, policies, users, or public expectations change. A guardrail is to define review intervals and change triggers.

Another failure mode is unclear ownership. When everyone is responsible in general, no one may be responsible in practice. A guardrail is to assign an accountability owner and name escalation pathways.

A third failure mode is relying on vendor claims or informal staff confidence without documentation. A guardrail is to require evidence artifacts that can be reviewed by governance, leadership, privacy, legal, equity, security, or program teams.

## Application to AI-Supported Workflows

This topic applies across generative AI, predictive analytics, NLP, RAG, automation, and agentic workflows. The more sensitive the data, the more consequential the output, or the more automated the action, the stronger the documentation, review, and monitoring expectations should be.

## Reflection Questions

What public health decision or workflow does this topic affect?

Who has authority to approve or pause the work?

What evidence would show that the workflow is responsible and effective?

What equity, privacy, legal, security, or public trust risks require review?

How will the agency know when the workflow needs to be revised?

---

## Practical Exercise

Create a practical third-party ai risk management artifact for one AI-supported public health use case. The artifact should define the use case, affected roles, review criteria, safeguards, documentation expectations, escalation triggers, monitoring indicators, and next review date.

## Expected Artifact or Evidence

Third-Party AI Risk Management artifact

Role and responsibility table

Risk and safeguard summary

Escalation and monitoring plan

Approval or review note

## Expected Assignment

- Third-Party AI Risk Management artifact
- Role and responsibility table
- Risk and safeguard summary
- Escalation and monitoring plan
- Approval or review note

## Knowledge Check

- 1. What is the strongest evidence that third-party ai risk management has been applied responsibly?
- 2. What is the best reason to assign an accountability owner?
- 3. When should an AI-supported workflow be escalated for review?
- 4. Which practice best supports public accountability?
- 5. What should happen when data sources, policy, vendor configuration, or workflow use changes?

## References and Resources

- CDC Public Health Data Strategy and Data Modernization resources: <https://www.cdc.gov/public-health-data-strategy/php/about/index.html>
- NIST Artificial Intelligence Risk Management Framework and NIST Generative AI Profile: <https://www.nist.gov/publications/artificial-intelligence-risk-management-framework-generative-artificial-intelligence>
- WHO Ethics and Governance of Artificial Intelligence for Health guidance: <https://www.who.int/publications/i/item/9789240029200>
- OWASP Top 10 for Large Language Model Applications: <https://owasp.org/www-project-top-10-for-large-language-model-applications/>
- ONC health IT, interoperability, and information blocking resources: <https://www.healthit.gov/>
- Agency policies for privacy, public records, cybersecurity, procurement, civil rights, accessibility, language access, and emergency communications